

Definição das Políticas no Nível Estratégico

Objetivo da Aula

Compreender a Política de Segurança de Nível Estratégico e estabelecer papéis e responsabilidades, especialmente os da alta administração, que desempenham um papel vital na integração da segurança da informação à estratégia de negócios. Conversaremos também sobre a necessidade de atender à conformidade regulatória e à revisão periódica do processo.

Apresentação

A Política de Segurança de Nível Estratégico, frequentemente denominada Política de Segurança da Informação (POSIC), desempenha um papel crucial na governança da segurança da informação de uma organização. Este documento é fundamental para definir as diretrizes, princípios e estratégias gerais relacionadas à segurança da informação, com ênfase na sua integração com os objetivos de negócios.

Nesta aula, exploraremos a importância da POSIC e como ela deve ser alinhada com a visão e missão da organização. Também discutiremos a identificação das áreas-chave que requerem proteção e os papéis e responsabilidades estratégicas na gestão da segurança da informação. Além disso, abordaremos a conformidade regulatória e a necessidade de revisão contínua da política de segurança. A compreensão desses conceitos é essencial para estabelecer uma base sólida e eficaz de segurança da informação no nível estratégico.

1. O que É a Política de Segurança de Nível Estratégico?

A política de segurança no nível estratégico, muitas vezes chamada de Política de Segurança da Informação, é um documento fundamental, que estabelece as diretrizes e os princípios gerais relacionados à segurança da informação em uma organização, com um foco específico nas estratégias e objetivos de negócios. Essa política é uma declaração de alto nível, que define a abordagem da organização para proteger seus ativos de informação críticos e garantir a continuidade dos negócios. Costuma ser chamada de Política de Segurança de Informação e Comunicação, ou POSIC.

A política de segurança no nível estratégico geralmente aborda os seguintes aspectos:

- **Missão e objetivos estratégicos:**

- Define a importância da segurança da informação no contexto dos objetivos estratégicos da organização;
- Declara claramente que a segurança da informação é essencial para atingir esses objetivos.

- **Proteção de ativos críticos:**

- Identifica os ativos de informação críticos para a organização e estabelece diretrizes para protegê-los;
- Isso pode incluir informações confidenciais, propriedade intelectual, dados de clientes, entre outros.

- **Gestão de riscos estratégicos:**

- Aborda a identificação e avaliação de riscos estratégicos que podem afetar a realização dos objetivos de negócios;
- Estabelece diretrizes para mitigar esses riscos.

- **Conformidade regulatória:**

- Declara o compromisso da organização em cumprir as regulamentações legais e regulatórias que afetam a segurança da informação no nível estratégico;
- Isso pode incluir leis de privacidade, regulamentos do setor e outras obrigações.

- **Papéis e responsabilidades estratégicas:**

- Define os papéis e responsabilidades de liderança na gestão da segurança da informação;
- Isso inclui o envolvimento da alta administração na definição de diretrizes estratégicas.

- **Integração com a estratégia de negócios:**

- Assegura que a estratégia de segurança da informação esteja alinhada com a estratégia de negócios mais ampla, permitindo que a segurança não seja um obstáculo, mas, sim, um facilitador do sucesso organizacional.

- **Revisão e atualização:**

- Estabelece a importância da revisão e atualização contínua da política para garantir que ela permaneça eficaz diante das mudanças no ambiente de ameaças e nas necessidades da organização.

A política de segurança no nível estratégico é um documento fundamental na governança de segurança da informação, pois fornece uma base para o desenvolvimento de políticas, procedimentos e práticas mais detalhadas em níveis táticos e operacionais. Ela serve como um guia para a liderança sênior da organização, garantindo que a segurança da informação seja integrada eficazmente às estratégias de negócios e à proteção de ativos críticos.

2. Alinhar Objetivos Estratégicos de Segurança com a Visão da Organização

O estabelecimento de metas de segurança alinhadas com a missão e visão da organização é um componente essencial na definição de objetivos estratégicos na política de segurança da informação. Essa prática assegura que a segurança da informação seja integrada à estratégia global da organização, e não à uma entidade separada. Aqui estão alguns pontos importantes sobre esse processo:

- **Alinhamento com a missão e visão:** a missão de uma organização define seu propósito fundamental, enquanto a visão representa o futuro desejado. Os objetivos de segurança devem estar em harmonia com esses princípios. Por exemplo, se a missão da empresa é fornecer produtos de alta qualidade, a segurança da informação deve ser projetada para garantir que os dados do cliente não sejam comprometidos, afetando a qualidade dos produtos e a confiança dos clientes;
- **Contribuição para objetivos globais:** os objetivos de segurança não devem ser estabelecidos isoladamente; em vez disso, eles devem ser formulados para apoiar e contribuir para os objetivos globais da organização. Isso significa que a segurança da informação não deve ser vista apenas como uma despesa ou um obstáculo, mas como um facilitador do sucesso organizacional;
- **Proteção de ativos estratégicos:** os ativos de informação críticos para a realização da missão e visão da organização devem ser identificados e protegidos. Isso pode incluir informações confidenciais, propriedade intelectual, dados de clientes, sistemas de TI essenciais e outros recursos fundamentais para os negócios;
- **Consideração de ameaças estratégicas:** as metas de segurança devem levar em consideração as ameaças estratégicas que podem afetar a organização. Por exemplo, em um ambiente de negócios globalizado, as ameaças cibernéticas podem representar uma preocupação estratégica. Portanto, as metas de segurança devem incluir a proteção contra essas ameaças;

- **Sustentabilidade e crescimento:** as metas de segurança devem ser formuladas de maneira a permitir a sustentabilidade e o crescimento da organização. Isso significa que a segurança não deve ser um impedimento à inovação e expansão, mas, sim, uma garantia de que os riscos são gerenciados adequadamente durante o processo;
- **Comunicação e conscientização:** além de estabelecer metas, é essencial comunicá-las e criar conscientização em toda a organização. Os funcionários devem entender como suas ações estão alinhadas com os objetivos estratégicos de segurança e como contribuem para o sucesso geral;
- **Métricas de avaliação:** as metas de segurança devem ser mensuráveis, e métricas apropriadas devem ser estabelecidas para avaliar o progresso em direção a essas metas. Isso permite que a organização acompanhe e ajuste suas iniciativas de segurança conforme necessário.

Em resumo, estabelecer metas de segurança alinhadas com a missão e visão da organização é fundamental para assegurar que a segurança da informação seja integrada à estratégia global, e não seja vista como uma preocupação separada. Isso contribui para a proteção de ativos críticos, o crescimento sustentável e a realização dos objetivos estratégicos da organização.

3. Identificação das Áreas-Chave

Um dos passos fundamentais no processo de elaboração da política no nível estratégico é a identificação de áreas-chave que requerem proteção. Essas áreas-chave compreendem ativos de informação essenciais para o funcionamento da organização e que, se comprometidos, podem resultar em consequências significativas.

A identificação de áreas-chave é uma prática estratégica que envolve a determinação dos ativos de informação de valor inestimável para a organização. Esses ativos podem incluir, mas não se limitam a:

- **Propriedade intelectual:** isso abrange informações, ideias e inovações únicas desenvolvidas pela organização, como patentes, segredos comerciais e direitos autorais;
- **Dados de clientes:** informações confidenciais relacionadas aos clientes da organização, incluindo dados pessoais, históricos de compras e informações de contato;
- **Informações financeiras:** dados financeiros críticos, como relatórios de resultados, informações de contas bancárias e projeções financeiras;

- **Sistemas de TI críticos:** a infraestrutura de tecnologia da informação é vital para as operações da organização, incluindo servidores, sistemas de gestão, bancos de dados e aplicativos essenciais;
- **Outros recursos essenciais:** recursos fundamentais para os negócios, como planos de negócios, estratégias de marketing, acordos contratuais, registros de funcionários, entre outros.

A identificação dessas áreas-chave é um processo que requer uma análise criteriosa. Podendo envolver a colaboração de diversas partes interessadas, incluindo departamentos de TI, jurídico, finanças e gestão de projetos. A avaliação leva em consideração o impacto potencial da perda ou comprometimento dessas áreas-chave, incluindo riscos financeiros, danos à reputação, litígios e interrupções nas operações.

Uma vez identificadas as áreas-chave, a organização pode priorizar seus esforços de segurança e alocar recursos de maneira eficaz para proteger esses ativos críticos. Isso permite que a política de segurança seja adaptada para atender às necessidades específicas da organização e garantir a proteção de seus ativos mais valiosos. A identificação de áreas-chave é, portanto, um componente essencial para a elaboração de políticas de segurança que sejam alinhadas com as prioridades e estratégias da organização.

4. Papéis e Responsabilidades Estratégicas na SegInfo (Segurança da Informação)

A gestão eficaz da segurança da informação requer uma clara definição de papéis e responsabilidades em todos os níveis da organização. No nível estratégico, a alta administração desempenha um papel fundamental na formulação, aprovação e implementação da política de segurança.

Vamos explorar em detalhes os papéis e responsabilidades das lideranças na gestão da segurança da informação e como o envolvimento da alta administração é essencial para o sucesso da política de segurança.

4.1. Papéis Estratégicos

- **Diretor de Segurança da Informação (CISO):** o CISO é o líder de segurança da informação da organização. Suas responsabilidades incluem a definição da estratégia de segurança, a supervisão da implementação de medidas de segurança e a gestão de incidentes de segurança. O CISO é o principal defensor da segurança da informação no nível estratégico e relata diretamente à alta administração;

- **Alta administração:** a alta administração, incluindo o CEO, diretores e membros do conselho, desempenha um papel fundamental na formulação da estratégia de segurança da informação. Eles são responsáveis por:
 - Definir as prioridades estratégicas de segurança da informação;
 - Aprovar políticas de segurança e orçamentos relacionados;
 - Estabelecer uma cultura de segurança organizacional;
 - Garantir a conformidade com regulamentações e requisitos de governança.

4.2. Responsabilidades Estratégicas

- **Definição de estratégia de segurança:** a alta administração é responsável por definir a estratégia de segurança da informação, alinhando-a com os objetivos de negócios. Isso envolve a identificação de ameaças e riscos estratégicos, bem como a determinação das metas de segurança;
- **Aprovação de políticas de segurança:** a política de segurança, que define as diretrizes gerais para a proteção de ativos de informação, deve ser aprovada pela alta administração. Isso estabelece o compromisso da liderança com a segurança da informação;
- **Alocação de recursos:** a alta administração é responsável por alocar recursos financeiros e humanos para a implementação das medidas de segurança. Isso inclui a aprovação de orçamentos para tecnologias, treinamento e pessoal de segurança;
- **Criação de cultura de segurança:** é dever da alta administração promover uma cultura de segurança na organização. Isso envolve a comunicação da importância da segurança, o estabelecimento de normas de conduta e a demonstração de comportamentos seguros;
- **Monitoramento e revisão:** a liderança deve monitorar regularmente o progresso em relação às metas de segurança e revisar a eficácia das medidas implementadas. Isso ajuda a garantir que a estratégia de segurança permaneça alinhada com as necessidades da organização.

4.3. Importância do Envolvimento da Alta Administração

O envolvimento ativo da alta administração é essencial para o sucesso da política de segurança por várias razões:

- **Comprometimento organizacional:** quando a alta administração demonstra um forte compromisso com a segurança da informação, esse comprometimento é refletido em

toda a organização. Os funcionários são mais propensos a aderir às práticas de segurança quando veem que a liderança valoriza a segurança;

- **Alocação de recursos:** a alta administração tem autoridade para alocar recursos financeiros e de pessoal para a segurança da informação. Isso garante que as medidas de segurança tenham os recursos necessários para serem eficazes;
- **Definição de prioridades:** a liderança define as prioridades estratégicas da organização. Ao alinhar a segurança da informação com essas prioridades, ela garante que a segurança seja incorporada à estratégia global de negócios;
- **Responsabilidade e prestação de contas:** a alta administração é responsável perante as partes interessadas, reguladores e acionistas. Se ocorrerem violações de segurança ou não conformidade regulatórias, a liderança é responsabilizada. Portanto, seu envolvimento garante uma abordagem proativa para a segurança da informação;
- **Tomada de decisões informadas:** a alta administração toma decisões estratégicas com base em informações críticas. Ter uma compreensão sólida das questões de segurança da informação permite que eles tomem decisões informadas que protegem a organização contra ameaças cibernéticas e riscos estratégicos.

Em resumo, os papéis e responsabilidades das lideranças no nível estratégico são essenciais para o desenvolvimento e implementação bem-sucedida de políticas de segurança. O envolvimento ativo da alta administração garante que a segurança da informação seja uma prioridade organizacional, alinhada com a estratégia de negócios e com recursos adequados para proteger ativos críticos e enfrentar ameaças cibernéticas.

5. Conformidade Regulatória e Revisão da Política de Segurança

A conformidade regulatória e a revisão contínua da política de segurança desempenham um papel interligado e essencial na gestão eficaz da segurança da informação em uma organização.

A conformidade regulatória é um pilar fundamental da segurança da informação. As regulamentações legais e regulatórias são estabelecidas para garantir a proteção de dados, privacidade, transparência e integridade das operações. Integrar as exigências regulatórias à política de segurança é necessário por várias razões:

- **Proteção legal:** as regulamentações legais frequentemente estipulam medidas específicas que as organizações devem adotar para proteger informações sensíveis. O não cumprimento dessas regulamentações pode resultar em implicações legais graves, incluindo multas significativas;
- **Proteção de dados pessoais:** muitas regulamentações, como a LGPD aqui no Brasil, impõem a proteção rigorosa de dados pessoais. Isso não apenas protege a privacidade dos indivíduos, mas também a reputação da organização;
- **Conquista da confiança do cliente:** o cumprimento das regulamentações demonstra um compromisso com a transparência e a segurança dos dados. Isso, por sua vez, constrói a confiança dos clientes, aumentando a fidelidade e a reputação da organização;
- **Redução de riscos e responsabilidade:** cumprir regulamentações ajuda a reduzir os riscos associados a violações de segurança. Além disso, evidencia um nível adequado de diligência e responsabilidade em relação à segurança da informação.

A não conformidade regulatória pode acarretar consequências significativas para uma organização. Isso inclui a possibilidade de enfrentar multas financeiras substanciais devido ao não cumprimento das normas de segurança de dados, o que pode impactar negativamente as finanças da empresa. Além disso, a violação de dados resultante da não conformidade pode abalar a confiança do cliente, levando a uma redução na base de clientes e danos duradouros à reputação da organização.

Também é importante observar que a não conformidade pode resultar em litígios e processos judiciais movidos por partes prejudicadas, como clientes e acionistas, o que pode ser dispendioso e demorado. Em alguns casos, a não conformidade regulatória pode levar a proibições de operação em mercados ou setores específicos, resultando na perda de oportunidades de negócios.

A revisão e atualização contínua da política de segurança são essenciais para garantir a eficácia da estratégia de segurança. A segurança da informação é um campo em constante evolução, com novas ameaças emergindo regularmente. Portanto, a revisão periódica da política de segurança é fundamental por diversos motivos, como:

- **Adaptação às mudanças no ambiente de ameaças:** novas ameaças cibernéticas surgem constantemente. A revisão da política permite a adaptação e implementação de medidas de segurança atualizadas para enfrentar essas ameaças emergentes;

- **Mudanças nas necessidades da organização:** à medida que a organização cresce e evolui, suas necessidades de segurança podem mudar. A revisão contínua garante que a política de segurança continue a ser relevante e atenda às necessidades da organização;
- **Aprendizado com incidentes:** incidentes de segurança passados podem fornecer *insights* valiosos. A revisão da política após um incidente permite a identificação de áreas que precisam de aprimoramento;
- **Manutenção da conformidade:** regulamentações e requisitos de conformidade também evoluem. A revisão da política garante que a organização permaneça consoante as últimas regulamentações;
- **Métricas e avaliação:** a revisão contínua permite que a organização estabeleça métricas de avaliação para medir o progresso em direção às metas de segurança. Isso ajuda a manter a responsabilidade e o acompanhamento.

Considerações Finais da Aula

A Política de Segurança de Nível Estratégico é um elemento fundamental na proteção de ativos de informação e na garantia da continuidade dos negócios em um ambiente cada vez mais complexo e ameaçador. Como discutido ao longo desta aula, essa política define a estratégia de segurança, alinha-a com a missão e visão da organização e identifica áreas-chave de proteção. Ainda, ela estabelece papéis e responsabilidades, especialmente os da alta administração, que desempenham um papel vital na integração da segurança da informação à estratégia de negócios. Além disso, a conformidade regulatória e a revisão periódica são peças-chave para garantir que a política de segurança permaneça relevante e eficaz.

Ao encerrar esta aula, é importante destacar que a segurança da informação não é uma tarefa estática, mas, sim, um processo dinâmico. As organizações enfrentam ameaças em constante evolução, e, portanto, devem manter suas políticas de segurança alinhadas com essas mudanças. A conformidade regulatória desempenha um papel essencial na proteção de dados e no cumprimento das leis, enquanto a revisão contínua da política de segurança permite que a organização se adapte às novas ameaças e às necessidades em constante evolução.

Ao implementar uma política de segurança de nível estratégico sólida e ao adotar uma abordagem proativa na gestão da segurança da informação, as organizações estão bem posicionadas para enfrentar desafios futuros, proteger seus ativos de informação críticos e promover a confiança do cliente. A integração eficaz da segurança da informação nas

estratégias de negócios é uma medida essencial para alcançar o sucesso organizacional em um mundo digital cada vez mais interconectado e dependente de dados. Portanto, a atenção à política de segurança de nível estratégico é uma parte essencial do cenário atual de segurança da informação.

Material Complementar



Regulação do sistema financeiro

2024, Banco Central do Brasil.

O Sistema Financeiro Nacional (SFN) é formado por um conjunto de entidades e instituições que promovem a intermediação financeira, isto é, o encontro entre credores e tomadores de recursos. Ele opera sob regras estabelecidas pelo Conselho Monetário Nacional (CMN), pelo Banco Central (BC) e pela Comissão de Valores Mobiliários (CVM), para garantir a eficiência da intermediação de recursos e promover a estabilidade financeira. No site do Banco Central do Brasil, você pode conhecer como essa regulação é feita, saber se sua empresa está regulada e quais normas regulatórias ela está sujeita. Disponível em: <https://www.bcb.gov.br/estabilidadefinanceira/regulacao>. Acesso em: 1º dez. 2023.

Referências

BENZ, K. H. **Alinhamento estratégico entre as políticas de segurança da informação e as estratégias e práticas adotadas na TI: estudos de caso em instituições financeiras**. Dissertação (mestrado) – Universidade Federal do Rio Grande do Sul, Escola de Administração, Programa de Pós-graduação em Administração, 2008. Disponível em: <https://lume.ufrgs.br/handle/10183/12905>. Acesso em: 16 ago. 2023.

PLANEJAMENTO estratégico em tecnologia da informação: um estudo sobre as dificuldades para implantação em uma instituição de ensino superior. **IBICT**, 2016. Disponível em: https://bdtd.ibict.br/vufind/Record/UFBA-2_14506dd17acf9e65bb57551ef4230ee2. Acesso em 16 de agosto de 2023.

REGULAÇÃO do sistema financeiro. **Banco Central do Brasil**, 2024. Disponível em: <https://www.bcb.gov.br/estabilidadefinanceira/regulacao>. Acesso em: 1º dez. 2023.